



ANALISI DELLE VULNERABILITÀ E REMEDIATION SU METASPLOITABLE

UTILIZZO DI NESSUS PER LA SCANSIONE, L'ANALISI E LA MITIGAZIONE DELLE VULNERABILITÀ

ANALISI DELLE VULNERABILITÀ E REMEDIATION SU METASPLOITABLE

IN QUESTO PROGETTO È STATA ESEGUITA UNA SCANSIONE DI SICUREZZA SULLA MACCHINA VULNERABILE METASPLOITABLE 2 UTILIZZANDO NESSUS ESSENTIALS. SUCCESSIVAMENTE SONO STATE ANALIZZATE DUE VULNERABILITÀ CRITICHE, APPLICATE LE RELATIVE AZIONI DI REMEDIATION E VERIFICATA LA LORO RISOLUZIONE MEDIANTE UNA NUOVA SCANSIONE.

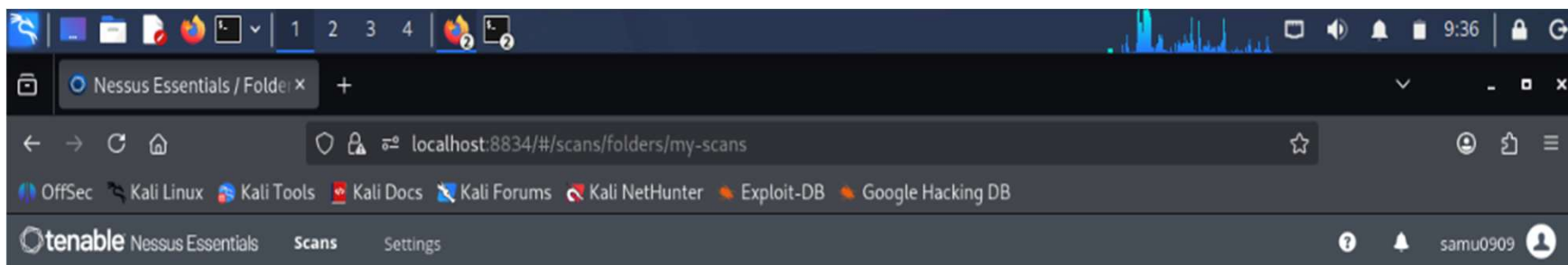
L'ATTIVITÀ È STATA SVOLTA IN UN AMBIENTE VIRTUALE COMPOSTO DA UNA MACCHINA KALI LINUX, UTILIZZATA COME SISTEMA DI ANALISI, E DA UNA MACCHINA METASPLOITABLE, CONFIGURATA COME TARGET VULNERABILE. LA SCANSIONE È STATA EFFETTUATA CON NESSUS ESSENTIALS.

Kali linux

```
kali@kali: ~  
Session Actions Edit View Help  
zsh: corrupt history file /home/kali/.zsh_history  
~(kali@kali)-[~]  
$ ip a  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000  
    link/ether 08:00:27:8a:35:d2 brd ff:ff:ff:ff:ff:ff  
    inet 192.168.50.100/24 brd 192.168.50.255 scope global eth0  
        valid_lft forever preferred_lft forever  
    inet6 fe80::a00:27ff:fe8a:35d2/64 scope link proto kernel_ll  
        valid_lft forever preferred_lft forever  
~(kali@kali)-[~]  
$
```

Metasploitable

```
To access official Ubuntu documentation, please visit:  
http://help.ubuntu.com/  
No mail.  
nsfadmin@metasploitable:~$ ifconfig  
eth0      Link encap:Ethernet  HWaddr 08:00:27:f3:57:8f  
          inet addr:192.168.50.101 Bcast:192.168.50.255 Mask:255.255.255.0  
          inet6 addr: fe80::a00:27ff:fef3:578f/64 Scope:Link  
          UP BROADCAST RUNNING MULTICAST  MTU:1500 Metric:1  
          RX packets:0 errors:0 dropped:0 overruns:0 frame:0  
          TX packets:27 errors:0 dropped:0 overruns:0 carrier:0  
          collisions:0 txqueuelen:1000  
          RX bytes:0 (0.0 B)  TX bytes:2954 (2.8 KB)  
          Base address:0xd020 Memory:f0200000-f0220000  
lo        Link encap:Local Loopback  
          inet addr:127.0.0.1 Mask:255.0.0.0  
          inet6 addr: ::1/128 Scope:Host  
          UP LOOPBACK RUNNING  MTU:16436 Metric:1  
          RX packets:91 errors:0 dropped:0 overruns:0 frame:0  
          TX packets:91 errors:0 dropped:0 overruns:0 carrier:0  
          collisions:0 txqueuelen:0  
          RX bytes:19301 (18.8 KB)  TX bytes:19301 (18.8 KB)  
nsfadmin@metasploitable:~$
```



SCANSIONE INIZIALE

È stata eseguita una scansione completa del sistema Metasploitable. Il report ha evidenziato numerose vulnerabilità classificate per livello di gravità (Critical, High, Medium e Low). Tra queste sono state selezionate la vulnerabilità Bind Shell Backdoor Detection e NFS share world readable .

Filter	Search Vulnerabilities	69 Vulnerabilities							
Sev	CVSS	VPR	EPSS	Name	Family	Count			
☐	CRITICAL	10.0			Canonical Ubuntu Linux SEoL (8.04.x)	General	1		
☐	CRITICAL	10.0 *			VNC Server 'password' Password	Gain a shell remotely	1		
☐	CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection	Service detection	2		
☐	CRITICAL	9.8			Bind Shell Backdoor Detection	Backdoors	1		
☐	CRITICAL	...	...	...	SSL (Multiple Issues)	Gain a shell remotely	3		
☐	MIXED	...	...	...	Apache Tomcat (Multiple Issues)	Web Servers	3		
☐	HIGH	7.5 *	6.7	0.5006	rlogin Service Detection	Service detection	1		
☐	HIGH	7.5	5.9	0.7852	Samba Badlock Vulnerability	General	1		
☐	HIGH	7.5			NFS Shares World Readable	RPC	1		

VULNERABILITÀ : BIND SHELL BACKDOOR DETECT



Questo tipo di vulnerabilità ci dice che una shell è in ascolto su una porta remota senza autenticazione. Un malintenzionato potrebbe sfruttare questa cosa connettendosi alla porta e prendere il controllo. Per risolvere questa vulnerabilità ho usato i seguenti comandi:

- «ufw enable» per attivare il firewall
- «ufw default ALLOW» che permette tutte le connessioni di base.
- «ufw deny 1524» per chiudere la seguente porta che è responsabile della backdoor.

Così facendo non risulterà più come vulnerabilità critica.

```
udp      0      0 192.168.50.101:138  0.0.0.0:*
-
udp      0      0 0.0.0.0:138        0.0.0.0:*
-
udp      0      0 0.0.0.0:43148      0.0.0.0:*
-
udp      0      0 0.0.0.0:43667      0.0.0.0:*
-
udp      0      0 192.168.50.101:53  0.0.0.0:*
-
udp      0      0 127.0.0.1:53       0.0.0.0:*
-
udp      0      0 0.0.0.0:69         0.0.0.0:*
-
udp      0      0 0.0.0.0:35679      0.0.0.0:*
-
udp      0      0 0.0.0.0:111        0.0.0.0:*
-
udp6     0      0 :::53              :::*
-
udp6     0      0 :::41197           :::*
-
nsfadmin@netasploitable:~$ sudo ufw deny 1524
Rule added
nsfadmin@netasploitable:~$
```

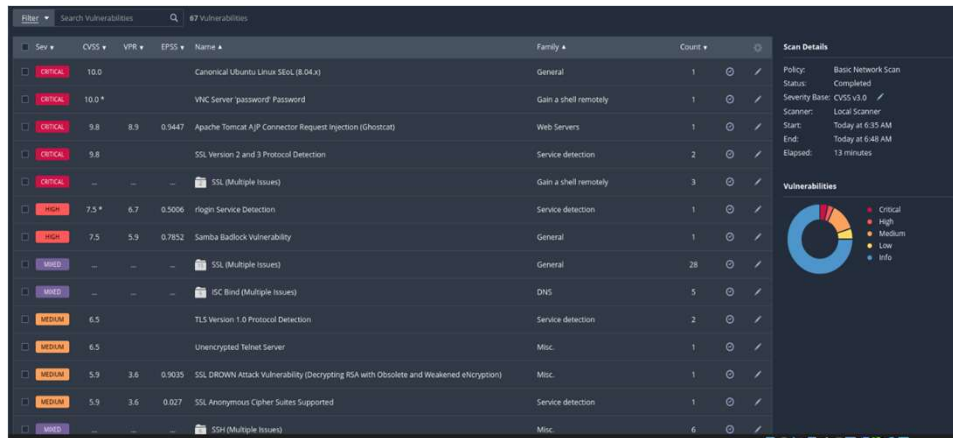
VULNERABILITÀ: NFS SHARE WORLD READABLE

NFS è un protocollo per la condivisione di file e directory e, se non è configurato in maniera sicura, potrebbe consentire a dei malintenzionati di accedere a risorse non autorizzate. Per aggirare questo problema ho modificato il file `/etc/exports` e ho modificato l'ultima riga perché in questa c'era il simbolo «/» che sta a significare che si può montare tutto. Mettendolo a commento con il simbolo «#» ho risolto questa vulnerabilità.

```
msfadmin@metasploitable:~$ vncpasswd
Using password file /home/msfadmin/.vnc/passwd
VNC directory /home/msfadmin/.vnc does not exist, creating.
Password:
Verify:
Would you like to enter a view-only password (y/n)? y
Password:
Verify:
msfadmin@metasploitable:~$
```

```
GNU nano 2.0.7      File: /etc/exports
# /etc/exports: the access control list for filesystems which may be exported
#                 to NFS clients.  See exports(5).
#
# Example for NFSv2 and NFSv3:
# /srv/homes      hostname1(rw,sync) hostname2(ro,sync)
#
# Example for NFSv4:
# /srv/nfs4       gss/krb5i(rw,sync,fsid=0,crossmnt)
# /srv/nfs4/homes gss/krb5i(rw,sync)
#
# *(rw,sync,no_root_squash,no_subtree_check)
```

SCANSIONE FINALE



The screenshot displays a vulnerability scanner interface with a table of findings and a summary section on the right.

Sev	CVE	VPR	EPSS	Name	Family	Count
CRITICAL	10.0			Canonical Ubuntu Linux S01 (R04.x)	General	1
CRITICAL	10.0 *			VNC Server 'password' Password	Gain a shell remotely	1
CRITICAL	9.8	8.9	0.9447	Apache Tomcat AJP Connector Request Injection (Ghostcat)	Web Servers	1
CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection	Service detection	2
CRITICAL	—	—	—	SSL (Multiple Issues)	Gain a shell remotely	3
HIGH	7.5 *	6.7	0.5006	rlogin Service Detection	Service detection	1
HIGH	7.5	5.9	0.7852	Samba Backdoor Vulnerability	General	1
MEDIUM	—	—	—	SSL (Multiple Issues)	General	28
MEDIUM	—	—	—	ISC Bind (Multiple Issues)	DNS	5
MEDIUM	6.5			TLS Version 1.0 Protocol Detection	Service detection	2
MEDIUM	6.5			Unencrypted Telnet Server	Misc.	1
MEDIUM	5.9	3.6	0.9035	SSL DROWN Attack Vulnerability (Decrypting RSA with Obsolete and Weakened e/cryption)	Misc.	1
MEDIUM	5.9	3.6	0.027	SSL Anonymous Cipher Suites Supported	Service detection	1
MEDIUM	—	—	—	SSH (Multiple Issues)	Misc.	6

Scan Details

- Policy: Basic Network Scan
- Status: Completed
- Severity Base: CVSS v3.0
- Scanner: Local Scanner
- Start: Today at 8:35 AM
- End: Today at 8:48 AM
- Elapsed: 13 minutes

Vulnerabilities

A pie chart showing the distribution of vulnerability severity levels: Critical (red), High (orange), Medium (yellow), Low (green), and Info (blue).

Dopo aver applicato le azioni di remediation è stata eseguita una nuova scansione completa. I risultati mostrano che le vulnerabilità Bind Shell Backdoor Detection e NFS Share World Readable non risultano più presenti, confermando l'efficacia degli interventi effettuati.

CONCLUSIONI

Filter

Search Vulnerabilities

Q

#9 Vulnerabilities

Sev	CVSS	VPR	EPSS	Name	Family	Count		
CRITICAL	10.0			Canonical Ubuntu Linux SEOL (B.04.x)	General	1		
CRITICAL	10.0 *			VNC Server 'password' Password	Gain a shell remotely	1		
CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection	Service detection	2		
CRITICAL	9.8			Bind Shell Backdoor Detection	Backdoors	1		
CRITICAL	—	—	—	📁 SSL (Multiple Issues)	Gain a shell remotely	3		
MED	—	—	—	📁 Apache Tomcat (Multiple Issues)	Web Servers	3		
HIGH	7.5 *	6.7	0.5006	rlogin Service Detection	Service detection	1		
HIGH	7.5	5.9	0.7852	Samba Badlock Vulnerability	General	1		
HIGH	7.5			NFS Shares World Readable	RPC	1		

Filter

Search Vulnerabilities

Q

67 Vulnerabilities

Sev	CVSS	VPR	EPSS	Name	Family	Count		
CRITICAL	10.0			Canonical Ubuntu Linux SEOL (B.04.x)	General	1		
CRITICAL	10.0 *			VNC Server 'password' Password	Gain a shell remotely	1		
CRITICAL	9.8	8.9	0.9447	Apache Tomcat AJP Connector Request Injection (Ghostcat)	Web Servers	1		
CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection	Service detection	2		
CRITICAL	—	—	—	SSL (Multiple Issues)	Gain a shell remotely	3		
HIGH	7.5 *	6.7	0.5006	rlogin Service Detection	Service detection	1		
HIGH	7.5	5.9	0.7852	Samba Badlock Vulnerability	General	1		
MIXED	—	—	—	SSL (Multiple Issues)	General	28		
MIXED	—	—	—	IC Bind (Multiple Issues)	DNS	5		
MEDIUM	6.5			TLS Version 1.0 Protocol Detection	Service detection	2		
MEDIUM	6.5			Unencrypted Telnet Server	Misc.	1		
MEDIUM	5.9	3.6	0.9035	SSL DROWN Attack Vulnerability (Decrypting RSA with Obsolete and Weakened encryption)	Misc.	1		
MEDIUM	5.9	3.6	0.027	SSL Anonymous Cipher Suites Supported	Service detection	1		
MIXED	—	—	—	SSH (Multiple Issues)	Misc.	6		

Scan Details

Policy: Basic Network Scan

Status: Completed

Severity Base: CVSS v3.0

Scanner: Local Scanner

Start: Today at 6:35 AM

End: Today at 6:48 AM

Elapsed: 13 minutes

Vulnerabilities

Critical

High

Medium

Low

Info

L'attività ha permesso di comprendere il processo di gestione delle vulnerabilità, dalla loro individuazione alla mitigazione e alla verifica finale. Le modifiche apportate hanno ridotto la superficie di attacco del sistema e migliorato il livello di sicurezza di Metasploitable